

BGRS Security Business Requirement Document

Bank Guarantee Repository System (BGRS)

Business Requirement Document (BRD) — Security

1. Executive Summary

BGRS processes **highly sensitive** bank guarantee, tender, contractor, and user data. The referenced security standard

mandates **defense in depth**: confidentiality and integrity of records, availability of services, prevention of unauthorized access, **full auditability**, and protection against cyber threats and data leakage.

This BRD translates each control in the source document into **business intent, risk, compliance context, expected behavior, user/department impact, audit implications, and module mapping** so management can prioritize investment and delivery teams can scope work without ambiguity.

Primary outcomes

2. Scope

2.1 In-scope

- All BGRS functional modules listed above.
- **Client, application, API, database, file storage, logging, backup/DR, and governance** controls from the source document.
- Organizational processes: access approval, incident response, retention, periodic security testing.

2.2 Out-of-scope (unless extended by the organization)

- Certification or security of **external** banking/SFMS systems outside BGRS's technical boundary.
- Physical security of user premises and unmanaged contractor devices (policy reference only).
- Legal interpretation of statutes (legal/DPO validates final compliance statements).

3. Assumptions

1. Primary access is via **browser** over internet or bank intranet with controlled egress.

2. **JWT** carries authenticated session claims; **RBAC** enforces business roles (naming may differ from sample roles in the source PDF).

3. Uploaded documents are **legal/evidentiary**; view/download must be **authorized and logged**.

4. **Maker-checker** applies to selected sensitive transitions (revocation, amendments, certain renewals, role changes) per bank policy.

4. Dependencies

5. Program Risks

6. Security Objectives (CIA+)

7. User Roles (Business Mapping)

Source document roles mapped to typical BGRS duties:

*Implementation may add roles (e.g. Verifier, Approver); **least privilege** still applies.*

8. Module-wise Security Mapping (Summary)

9. Security Workflow Overview (Conceptual)

sequenceDiagram

participant U as User

participant FE as Vue App

participant GW as TLS Edge

participant API as Spring Boot

participant DB as Database

participant FS as Private Storage

U->>FE: Login + MFA

FE->>GW: HTTPS /auth/login

GW->>API: Forward

API->>DB: Validate, audit login

API->>FE: JWT

FE->>GW: API + Bearer JWT

GW->>API: Validate JWT + RBAC

alt Authorized file access

API->>FS: Stream via service account

API->>DB: Audit VIEW/DOWNLOAD

end

10. Approval Matrix (Illustrative — confirm with bank)

11. Audit & Compliance (Cross-cutting)

- **Events to log**: authentication success/failure; upload/download/view; create/update/delete on critical entities; administrative actions; SFMS verification; approval steps.
- **Minimum log fields**: user id, timestamp, IP (or edge client id), action, entity type/id, correlation id; before/after snapshots or hashes where feasible.
- **Retention**: align document, audit, and application log retention with **legal hold** and **DPDP** purpose limitation.
- **Evidence for audits**: architecture, data-flow diagrams, DPIA summary, VAPT reports, DR test records, access review evidence.

12. Deployment & Operational Guidelines

- Production **TLS only**, HSTS, modern ciphers; no mixed content.
- **Secrets** in vault/KMS — not in source control or plain production config.
- **Network**: app tier ↔ DB ↔ storage segmented; admin paths IP-restricted.
- **Backups**: encrypted, **offsite/secondary region**, periodic **restore drills**.
- **Operations**: quarterly privileged access review; monthly patch/dependency review; documented **incident response**.

13. Requirement Catalog — Source Traceability

Each requirement below includes: **(1) Name (2) Business purpose (3) Problem solved (4) Modules (5) Risk (6) Workflow (7) Validation (8) Exceptions (9) Audit (10) Reporting (11) Roles (12) Notifications (13) Dependencies (14) Business rules (15) Sample scenario (16) Compliance.**

Risk: Critical | High | Medium | Low

Category A — Client-side security

REQ-CS-001 — HTTPS-only, trusted TLS, HTTP→HTTPS redirect

REQ-CS-002 — Session security (timeout, secure cookies, anti-session hijacking)

Secure cookies: if cookies used → `Secure`, `HttpOnly`, appropriate `SameSite`. Pure Bearer-in-memory still needs short TTL + idle timeout.

REQ-CS-003 — XSS, CSRF, security headers

REQ-CS-004 — Strong passwords, MFA/OTP, account lockout

REQ-CS-005 — Secure view/download (authorization + optional watermark)

Category B — Server-side security

REQ-SS-001 — Server hardening (remove defaults, minimal services, restricted admin)

REQ-SS-002 — OS patching; antivirus/anti-malware; endpoint protection

REQ-SS-003 — Firewall; restrict SSH/RDP; IP-based admin access

REQ-SS-004 — Secure hosting (approved/reputed cloud/DC, residency as required)

REQ-SS-005 — Secure API handling (authn/authz, rate limiting, token-based access)

***Consolidated business intent for REQ-SS-001–004: reduce host and network attack surface, ensure timely patching and monitoring, and host in approved environments. Risk: High for 001–004; Critical for API handling (005). Modules: all backend. Audit: admin access, firewall changes, API denial patterns. Compliance: organizational**

IS policy, CERT-In baselines.

Category C — Database & storage

REQ-DB-001 — DB not publicly accessible; least-privilege DB users

REQ-DB-002 — Encryption at rest (data + backups)

REQ-DB-003 — SQL injection prevention (parameterized queries / safe ORM use)

REQ-DB-004 — Secure file storage (no direct public URLs; protected paths)

REQ-DB-005 — Data integrity (hash/checksum; versioning for critical records)

Category D — Application security (SDLC)

REQ-APP-001 — OWASP Top 10 & CERT-In aligned practices

REQ-APP-002 — Input validation (all inputs; prevent malicious execution)

REQ-APP-003 — Secure error handling (no internal details to end users)

REQ-APP-004 — Dependency security (updates; avoid known-vulnerable libs)

Category E — User access & authentication

REQ-UAA-001 — RBAC (Super Admin, Dept Admin, Data Entry, Viewer, Auditor)

REQ-UAA-002 — Principle of least privilege

REQ-UAA-003 — Password complexity, expiry, hashing (not reversible)

REQ-UAA-004 — Multi-level approval for sensitive actions

Category F — File & document security

REQ-FILE-001 — Allowlist: PDF, JPG/JPEG, PNG, TIFF; block EXE, BAT, JS, PHP, executables

REQ-FILE-002 — Malware scanning on upload

REQ-FILE-003 — Secure renaming (non-guessable storage names)

REQ-FILE-004 — File size limits (client + server + proxy)

REQ-FILE-005 — Optional watermarking for sensitive records

Category G — Network & infrastructure

REQ-NET-001 — Segmentation; restricted internal communication

REQ-NET-002 — IDS/IPS; threat monitoring

REQ-NET-003 — DDoS protection

REQ-NET-004 — Secure DNS & routing monitoring

Category H — Backup & disaster recovery

REQ-BKP-001 — Backup DB, documents, logs, configurations

REQ-BKP-002 — Encrypted backups

REQ-BKP-003 — Multi-location backups

REQ-BKP-004 — DR procedures tested periodically

Category I — Monitoring & audit

REQ-MON-001 — Audit: login; upload/download; modifications; deletions; admin

REQ-MON-002 — Log fields: user id, timestamp, IP, activity details

REQ-MON-003 — Protect logs from tamper/unauthorized deletion

REQ-MON-004 — Monitor suspicious / abnormal access

Category J — Compliance & governance

REQ-COMP-001 — VA/PT/VAPT before go-live (mandatory #10)

REQ-COMP-002 — IT Act 2000, DPDP, CERT-In, organizational policies

REQ-COMP-003 — Data retention & archival policy

REQ-COMP-004 — Documented incident response & escalation

14. Mandatory Pre-Go-Live Controls (Source Section 4)

15. Recommended Best Practices (Source Section 3)

Mapped to requirements: HTTPS (REQ-CS-001); MFA for admins (REQ-CS-004); periodic audits (REQ-COMP-001, REQ-MON-004); backup restoration tests (REQ-BKP-004); patching (REQ-SS-002); restrict DB/storage exposure (REQ-DB-001, 004); Zero Trust patterns (segmentation + continuous verification + MFA).

16. Security Benefits & Risk of Non-Implementation (Summary)

17. Integration Impact on Existing BGRS Modules

End of BRD — Security (BGRS)